

Here is a foundational GRC Risk Register project tailored for a fictional small IT service provider.

Company Profile: "Apex IT Services"

Industry: IT Consultancy & Managed Services

Core Operations: Database management, endpoint security, and managed security awareness training (MSAT) for small-to-medium businesses.

Risk Register

This register outlines the inherent risks to the business, the controls currently in place, and the treatment plan to reduce the residual risk to an acceptable level.

Risk ID	Threat / Vulnerability	Inherent Risk	Existing Controls	Treatment Strategy	Residual Risk
R-01	Client Phishing Compromise : A client's employee falls for credential harvesting, leading to unauthorized network access.	High	Spam filtering; basic email security protocols.	Mitigate: Deploy mandatory, automated Managed Security Awareness Training (MSAT) for all client endpoints.	Low
R-02	Database SQL Injection: Malicious actors exploit poorly sanitized inputs on a hosted web app to access backend databases.	High	Web Application Firewall (WAF).	Mitigate: Implement strict parameterized queries; conduct routine vulnerability scans using automated penetration testing tools.	Medium
R-03	Vendor Supply Chain Breach: A third-party software	Critical	Standard vendor selection process.	Transfer & Mitigate: Require SOC 2 Type II reports from	Medium

Risk ID	Threat / Vulnerability	Inherent Risk	Existing Controls	Treatment Strategy	Residual Risk
	vendor is compromised, introducing malware into Apex IT's management tools.			critical vendors; maintain comprehensive cyber liability insurance.	
R-04	Unpatched System Exploitation: Vulnerabilities in Windows or Linux environments are exploited before patches are applied.	High	Manual monthly patch cycles.	Mitigate: Automate patch management workflows; deploy an AI-driven intrusion detection system (IDS) to flag anomalous traffic in real-time.	Low
R-05	Compliance Violation (Data Privacy): Failure to properly secure personally identifiable information (PII) leads to regulatory fines.	Medium	Privacy policy in place; basic encryption.	Mitigate: Map current data flows to standard GRC frameworks (like NIST CSF); enforce data-at-rest encryption across all storage arrays.	Low

Key Insight: A static risk register is only step one. The actual GRC value comes from how these treatment plans are audited and updated as the threat landscape shifts.